Корпоративный стандарт безопасной конфигурации инфраструктуры

1. Назначение и цели

Стандарт устанавливает обязательные требования к безопасной настройке инфраструктуры «Полёт»:

- АРМ на Windows 11;
- серверы DMZ (Nginx, OpenVPN);
- серверный сегмент (файловые серверы на Ubuntu 24.04);
- инфраструктурный сегмент (контроллер домена Windows, DNS на Ubuntu 24.04);
- маршрутизатор с межсетевым экраном.

Цели:

1. Закрыть уязвимости, выявленные пентестом.
2. Исключить слабую аутентификацию.
3. Не дать атакующему перемещаться по сети (сегментация, минимальные права).
4. Защитить персональные данные и финансовую информацию (152-ФЗ).
5. Обеспечить логирование и мониторинг.

2. Область применения

Стандарт обязателен для:

- всех сотрудников (HR, IT, менеджеры, бухгалтерия);
- администраторов и подрядчиков;
- всех систем из 1 пункта.

Исключения из требований стандарта возможны только на основании письменного согласования с отделом информационной безопасности и подлежат ежегодному пересмотру.

3. Общие принципы

Требования стандарта:

- исключают повторение атаки из пентеста;
- реализуют принцип минимальных привилегий;
- обеспечивают эшелонированную защиту;
- делают действия пользователей и админов прослеживаемыми.

В стандарте фиксируются обязательные требования, а не рекомендации.

4. Обязательные требования

4.1 Парольная политика в AD

1. Длина пароля — не менее 12 символов, с буквами разного регистра, цифрами и спецсимволами.
2. Смена пароля привилегированных учёток — раз в 90 дней.
3. Блокировка после 5 неудачных попыток на 30 минут.
4. Запрет паролей из утечек.
5. MFA для VPN, RDP и веб-портала.
6. Отказ от NTLM, переход на Kerberos.
7. LAPS для уникальных паролей локальных админов.

4.2 Отключение небезопасных протоколов

1. Отключить SMBv1.
2. Отключить Telnet, FTP, HTTP.
3. Отключить учётку Guest и анонимный доступ к сетевым ресурсам.
4. Запретить передачу паролей в открытом виде.

4.3 Сегментация сети

Сегменты:

- пользовательский (АРМ);
- DMZ (веб-приложение, VPN);
- серверный (файловые серверы, бухгалтерия);
- инфраструктурный (AD, DNS).

Ограничения:

1. Default Deny на межсетевом экране.
2. Из DMZ нельзя инициировать подключения во внутреннюю сеть (кроме необходимых портов).
3. Пользовательский сегмент не имеет прямого доступа к инфраструктурному (кроме портов для работы домена).
4. Доступ к серверному сегменту — строго по IP и портам.
5. Запретить сканирование сети (ICMP, ARP) между сегментами.

4.4 Управление привилегиями и учётными записями

1. Запретить права локального администратора обычным пользователям (HR, менеджеры, бухгалтеры).

2. Разделить учётки: обычная для работы, отдельная для администрирования.
3. Аудит учётных записей — раз в квартал.
4. Блокировать учётки подрядчиков сразу после завершения работ.
5. Запретить хранение паролей и SSH-ключей в открытом виде.

4.5 Управление уязвимостями и обновлениями

1. Сканирование уязвимостей — раз в квартал.
2. Критические патчи — в течение 14 дней.
3. Веб-приложения и сервисы запускать от непривилегированных пользователей (не root).
4. Внедрить WAF для веб-портала.
5. Проводить SAST и DAST для веб-приложений.

4.6 Защита контроллеров домена

1. Ограничить права на DCSync.
2. Включить Credential Guard.
3. Запретить вход на DC с обычных АРМ.
4. Использовать Tiered Administration (Tier 0 — DC, Tier 1 — серверы, Tier 2 — АРМ).
5. Мониторить целостность NTDS.dit.

4.7 Централизованное логирование и мониторинг

1. Сбор логов со всех серверов, АРМ и сетевого оборудования в SIEM/syslog.
2. Алерты на:
    - password spraying;
    - DCSync;
    - сканирование сети;
    - обратные туннели;
    - вход админов вне регламента.
3. Хранение логов — не менее 6 месяцев.
4. Синхронизация времени (NTP) на всех узлах.

5. Контроль выполнения

Контроль выполнения требований осуществляется отделом информационной безопасности не реже одного раза в год.

5.1 Периодичность

- Планово — раз в год.
- Внепланово:
    - после инцидентов;
    - после изменений инфраструктуры;
    - после увольнения админов или завершения работ подрядчиков;
    - перед внешним аудитом.

5.2 Ответственные

- Отдел ИБ — проверки, аудит логов.
- IT-отдел — техническая реализация.
- Руководители отделов — соблюдение требований сотрудниками.

5.3 Методы проверки

- Сканирование уязвимостей и конфигураций.
- Ручной анализ прав и конфигов.
- Анализ логов.
- Интервью с сотрудниками.
- Контрольные пентесты (раз в год).

5.4 Критерии соответствия

Требование выполнено, если:

- реализовано на 100% на всех системах;
- нет инцидентов, связанных с его невыполнением;
- пентест не выявил успешных атак через этот вектор.

Соответствие отчёта о пентесте и стандарта

Шаг пентеста	**Пункт в стандарте**
Вектор №1	

1. Подбор пароля qwerty123 к ppavlov	4.1
2. Подключение к VPN под ppavlov	4.1
3. Сканирование сети 10.126.0.0/16	4.3, 4.7
4. Password spraying, 10 учёток с одним паролем	4.1, 4.7
5. Вход по RDP на АРМ alvanova, она в группе админов	4.4
6. Вход по NTLM под it-admin	4.2
7. Компрометация NTDS.dit (DCSync)	4.6
8. Восстановление 80 из 100 паролей	4.1, 4.6
9. Вход на файловый сервер, кража ПДн клиентов	4.3, 4.4
Вектор №2	
1. RCE на веб-приложении	4.5
2. Запуск от root, найден SSH-ключ от DNS	4.4, 4.5
3. Вход на DNS по украденному ключу	4.4
4. Разведка на DNS, повышение привилегий не удалось	4.3
5. Сканирование сети 10.126.0.0/16	4.3, 4.7
6. Подключение к файловому ресурсу под Guest, найдена учётка buch_audit	4.2, 4.4

7. Доступ к финансовой информации под buch_audit	4.3, 4.4

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.